

WeHack

EMERGENCY RESPONSE GUIDE • 2026

The 72-Hour Breach Response Checklist

Exactly what to do in the first 72 hours after a cyber breach. Step-by-step. No panic. No guesswork. Includes NZ Privacy Act obligations.

29 min

AVG TIME ATTACKERS NEED

\$5.08M

AVG RANSOMWARE COST

83%

WHO PAY GET HIT AGAIN

The First 60 Minutes

The decisions you make in the first hour determine whether you lose thousands or millions.



Contain & Isolate

MINUTES 0 – 60 • CRITICAL WINDOW

1

Don't Panic — Activate Your Incident Lead

Designate one person to coordinate. This person makes all decisions for the next 72 hours. If you don't have an incident lead, the most senior available person takes this role. **Write down the time of discovery.**

2

Disconnect Affected Systems from the Network

Unplug ethernet cables. Disable Wi-Fi. Do NOT power off machines (forensic evidence is in RAM). Isolate affected devices but **keep them turned on**. If you power off, you lose critical evidence.

3

Change All Admin Passwords Immediately

Domain admin, cloud admin (Azure/AWS/GCP), email admin, firewall admin, VPN. Use a **clean device** to make these changes, not a potentially compromised one. Enable MFA if not already active.

4

Preserve Evidence

Screenshot everything: error messages, ransom notes, unusual files, running processes. Photograph screens if needed. **Do NOT delete anything**. Do NOT run antivirus yet — it can destroy forensic artefacts.

5

Document the Timeline

Start a log: when was the breach discovered? Who noticed it? What systems are affected? What's the current status? This timeline becomes critical for Privacy Commissioner reporting and insurance claims.

6

Call Your Incident Response Support

Contact your IT provider, cybersecurity partner, or insurer's IR hotline. If you have nobody: call **CERT NZ on 0800 CERT NZ (0800 2378 69)**. They provide free guidance to NZ businesses.

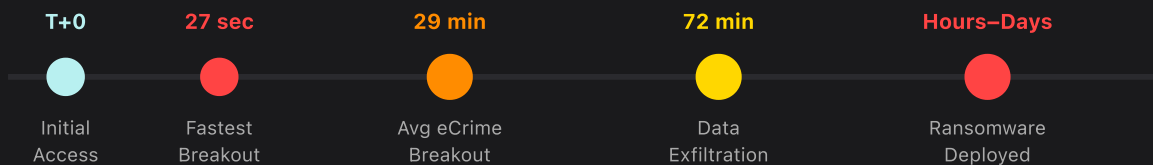
Why Speed Matters

The average eCrime breakout time is **29 minutes**. That's how fast attackers move from initial access to lateral movement across your network. The fastest recorded breakout: **27 seconds**. Internal detection saves an average of **\$900,000** compared to external notification. Sources: CrowdStrike 2026 GTR, Cobalt

What Attackers Actually Do (2026 TTPs)

Based on CrowdStrike's 2026 Global Threat Report and Unit 42's 2026 Incident Response data. This is how real breaches unfold in 2025-2026.

REAL-WORLD ATTACK TIMELINE



Your window to contain = minutes, not hours

The 2026 Attack Playbook (From CrowdStrike & Unit 42)

- **82% of detections are malware-free.** Attackers use valid credentials, living-off-the-land tools (PowerShell, WMI, PsExec), and legitimate remote access software. Your antivirus won't catch them. CrowdStrike 2026 GTR
- **40% of incidents start with vulnerability exploitation** — the #1 initial access vector in 2025-2026, surpassing phishing. Unpatched VPNs, firewalls, and web apps are the primary entry point. IBM X-Force 2026
- **Identity weaknesses found in 90% of investigations.** Overprivileged accounts, weak passwords, lack of MFA, and shared credentials are how attackers escalate from a foothold to full domain admin. Unit 42 2026
- **87% of attacks span multiple surfaces.** Attackers pivot from email to endpoint to cloud to SaaS. A breach in one system means every connected system is at risk. Unit 42 2026
- **Encryption-based extortion declined 15%.** Modern attackers skip encryption entirely — they steal your data and threaten to publish it. Faster, quieter, harder to detect. Unit 42 2026
- **49% increase in active ransomware groups YoY.** The ransomware ecosystem is fragmenting — more groups, smaller operations, more unpredictable. 7,000+ victims named on leak sites in 2025. IBM X-Force 2026, Cobalt

Why This Matters for Your Response

If you're reading this during a breach, understand: the attacker likely **already has your data**. Modern attacks exfiltrate before encrypting. Your immediate priority is **containment and credential**

revocation, not trying to decrypt files. The data is already gone — your job is to stop it getting worse and understand what was taken.

ManageMyHealth Breach — January 2026

The largest known NZ health data breach. Here's what happened, what went wrong, and what you can learn from it.

120K+

patients affected (6-7% of 1.8M users)

ManageMyHealth

108 GB

of sensitive health data exfiltrated

BlackVeil Security

\$60K

ransom demanded (real cost: millions)

NZ media

What Was Stolen

The "Kazu" threat group exfiltrated **400,000+ health documents** including clinical notes, lab results, vaccination records, and medical photographs. Multiple general practices across NZ were affected. The Privacy Commissioner launched a formal inquiry.

Lessons for Every NZ Business

- **Small ransoms mask massive costs.** The \$60K ransom was nothing compared to the regulatory investigation, legal liability, patient notification, reputational damage, and system rebuilds.
- **Health data is the highest-value target.** Healthcare breaches cost \$7.42M on average globally (2025). In NZ, the Privacy Act treats health information as one of the most sensitive categories.
- **Third-party platforms are YOUR responsibility.** If you use a SaaS provider to store client data, a breach of that provider is still YOUR breach. You must have vendor assessment and incident response plans.
- **Data exfiltration happens before you know.** By the time you discover the breach, 108GB of data may already be on the attacker's servers. Prevention and detection are the only real defences.

The Wider NZ Threat Landscape (2025-2026)

- **\$7.8 million lost in Q1 2025 alone** — a 14.7% increase and the second-highest quarterly loss ever recorded by NCSC. CERT NZ / NCSC
- **~1 nationally significant incident per day** handled by the NCSC. 300+ required specialist investigation. NCSC
- **26,000 New Zealanders contacted** about Lumma Stealer malware that was harvesting credentials from NZ devices. NCSC
- **92 instances of NZ/AU business access sold on the dark web** in 2025. Attackers are actively trading login credentials to NZ companies. NCSC
- **25% of nationally significant incidents linked to state-sponsored actors** who increasingly use AI-powered social engineering. NCSC Q1 2025

The Hard Truth for NZ SMBs

40% of NZ SMBs say a \$100,000 attack would shut them down (VikingCloud 2026). Yet only 38% of breach victims fix the vulnerability that allowed the initial attack (Cobalt). The ManageMyHealth breach shows it can happen to any NZ organisation — and the consequences are severe. The best time to prepare your response plan was last year. The second best time is now.

Hours 2 – 24

Now that you've contained the immediate threat, assess the damage and start your investigation.



Investigate & Assess

HOURS 2 – 24 • ASSESSMENT WINDOW

7

Determine the Scope of the Breach

What data was accessed? Customer records, financial data, health information, employee details? Which systems were compromised? How many records were potentially affected? This determines your legal obligations.

8

Identify the Entry Point

Was it phishing? A stolen credential? An unpatched vulnerability? A misconfiguration? Understanding the entry point is essential to preventing re-entry. **90% of incidents involved misconfigurations** that enabled the attack.

9

Check for Data Exfiltration

Review logs for large data transfers, unusual outbound connections, or cloud storage access. Attackers often exfiltrate data **before** deploying ransomware. 93% of ransomware victims who paid still had their data stolen.

10

Engage Legal Counsel

Your lawyer can advise on Privacy Act obligations, client communication, and insurance claims. If personal data was breached, you likely have a **mandatory notification obligation** under the NZ Privacy Act 2020.

11

Notify Your Cyber Insurance Provider

If you have cyber insurance, notify them within the required window (typically 24-48 hours). Delayed notification can void your coverage. Provide your incident timeline and evidence.

12

Prepare Internal Communications

Brief your leadership team. Prepare a holding statement for staff. Instruct employees NOT to discuss the breach externally or on social media until the official response is coordinated.

90%+

93%

\$900K

Hours 24 – 72

Notification, compliance, and beginning recovery. This is where legal obligations kick in.



Notify & Comply

HOURS 24 – 72 • COMPLIANCE WINDOW

13

Report to the NZ Privacy Commissioner

Under the **Privacy Act 2020**, you must notify the Privacy Commissioner of any breach that has caused, or is likely to cause, serious harm. Use NotifyUs: privacy.org.nz/notify-us. Report as soon as practicable.

14

Notify Affected Individuals

If the breach is likely to cause serious harm, you must also notify the affected individuals. Be honest, clear, and specific about what data was compromised and what actions they should take (e.g., change passwords, monitor accounts).

15

Report to CERT NZ / NCSC

Report the incident at cert.govt.nz/report or call **0800 CERT NZ**. For nationally significant incidents, the NCSC can provide specialist investigation support. They handled 300+ specialist cases in 2024/25.

16

File a Police Report

Report to NZ Police online at police.govt.nz. For significant financial loss, contact the Financial Crime Unit. Keep your incident number — insurers and the Privacy Commissioner may require it.

17

Communicate Externally

Prepare a public statement if needed. Be transparent but controlled. Focus on: what happened, what you're doing about it, and what affected parties should do. Avoid blame and speculation. Customers respect honesty.

18

Begin Remediation

Patch the vulnerability that was exploited. Only **38% of breach victims fix the vulnerability** that allowed the initial attack. Rebuild compromised systems from clean backups. Do NOT restore from backups that may also be compromised.

Since December 2020, NZ businesses have a **mandatory obligation** to report privacy breaches that cause or are likely to cause serious harm. Failure to comply can result in fines up to **\$10,000** for individuals or **investigation and enforcement action** by the Privacy Commissioner. The ManageMyHealth breach (January 2026) triggered a formal Privacy Commissioner inquiry after 120,000+ patient records were stolen. Source: Privacy Act 2020, NZ media

The "Do NOT" List

These common mistakes can turn a bad situation into a catastrophe. Print this page and tape it to the wall.



Do NOT Pay the Ransom

83% of businesses that paid were attacked again. 93% still had their data stolen. Paying funds criminal operations and marks you as a willing payer for future attacks.



Do NOT Power Off Compromised Machines

RAM contains forensic evidence (encryption keys, running processes, network connections). Disconnect from the network instead. Powering off destroys evidence your investigators need.



Do NOT Run Antivirus on Compromised Systems

Antivirus can quarantine or delete malware artefacts that forensic investigators need to understand the attack. Wait for professional guidance before cleaning any systems.



Do NOT Communicate with the Attacker

Unless directed by law enforcement or a professional negotiator. Responding can reveal information about your organisation, signal willingness to pay, or trigger accelerated data destruction.



Do NOT Delete Logs or Evidence

You may instinctively want to "clean up." Don't. Logs are your evidence trail for the Privacy Commissioner, insurers, police, and your own investigation. Preserve everything.



Do NOT Restore from Backup Without Verifying It's Clean

Attackers often compromise backups before deploying ransomware. Restoring an infected backup reinfects your systems. Verify backup integrity before any restoration.



Do NOT Make Public Statements Without Legal Review

What you say publicly can have legal, regulatory, and reputational consequences. Get legal sign-off before any press releases, social media posts, or customer emails.



Do NOT Assume It's Over

Attackers frequently maintain persistence (backdoors, new accounts, scheduled tasks). Only **38% of breach victims fix the original vulnerability**. Without thorough investigation, they'll be back.

Printable Response Checklist

Print this page and keep it accessible. When a breach happens, you won't have time to search for instructions.

Phase 1: First 60 Minutes

- ☐ **Incident lead designated.** One person coordinating all decisions.
- ☐ **Affected systems disconnected** from network (NOT powered off).
- ☐ **All admin passwords changed** from a clean device. MFA enabled.
- ☐ **Evidence preserved.** Screenshots taken, nothing deleted.
- ☐ **Timeline log started.** Discovery time, affected systems, current status.
- ☐ **IR support contacted.** IT provider, cyber partner, or CERT NZ (0800 2378 69).

Phase 2: Hours 2–24

- ☐ **Breach scope assessed.** What data, which systems, how many records.
- ☐ **Entry point identified.** Phishing? Credential theft? Unpatched vuln?
- ☐ **Data exfiltration checked.** Logs reviewed for outbound transfers.
- ☐ **Legal counsel engaged.** Privacy Act obligations assessed.
- ☐ **Cyber insurer notified.** Within required window (typically 24–48h).
- ☐ **Internal comms prepared.** Leadership briefed, staff instructed.

Phase 3: Hours 24–72

- ☐ **Privacy Commissioner notified** via NotifyUs (privacy.org.nz/notify-us).
- ☐ **Affected individuals notified** with clear, honest information.
- ☐ **CERT NZ report filed** at cert.govt.nz/report.
- ☐ **Police report filed.** Incident number recorded.

☐ **External communications sent.** Legal-reviewed, transparent.

☐ **Remediation started.** Vulnerability patched, clean backups verified, rebuild underway.

Key NZ Contacts

CERT NZ: 0800 2378 69

CERT NZ report: cert.govt.nz/report

Privacy Commissioner:

privacy.org.nz/notify-us

NZ Police online: police.govt.nz

If Ransomware

Do NOT pay. 83% who pay get attacked again.

Do NOT power off. Evidence is in RAM.

Do NOT restore backups without verification.

Call CERT NZ immediately.

WHAT'S NEXT

Prepare Before It Happens

The businesses that recover fastest are the ones that had a plan before the breach. Don't wait for the call from your IT team at 2am.

Find Your Gaps Before Attackers Do

Start with our free security assessment — 20 questions across 6 domains, with a personalised radar chart, risk exposure in NZD, and a prioritised action plan.

Take Your Free Security Score →

Every business has different security challenges. Book a free 15-minute chat and we'll recommend the right approach — no obligation.

Mustafa Demirsoy

Founder & Hacker, WeHack

wehack.co.nz | info@wehack.co.nz | 022 091 7242

148 Durham Street, Tauranga 3110

© 2026 WeHack | Data sourced from CrowdStrike 2026 GTR, IBM X-Force 2026, Cobalt, Unit 42, NCSC NZ, CERT NZ, NZ Privacy Act 2020

wehack.co.nz